Firewall Administration and Configuration

INSTRUCTIONS:
Please respond to each question by placing an "X" in the "Yes", "No" or "N/A" column or by providing the information requested. Use the "Tab" key to move between items. Use the "Additional information" field for explanatory comments, if necessary. If an item does not have an "Additional information" field, and you need to explain your answer, use the space at the end of the questionnaire and reference the item being explained, e.g. RE: Item 1.2-This is the explanation.

Questionnaire completed by: _____

Contact number for follow-up questions: _____

Date Completed: _____

1. Policies and Procedures

Number	Question	Yes	No	N/A
1.1	Is there a written firewall policy for the organization? *If you answered "No" to this question, skip to Section 2, Firewall Software* Additional information: _____	☐	☐	☐
1.2	Are there different firewall policies, procedures, devices or software used in different areas of your network? (for example: you have a different firewall policy or procedure or use different software or devices in your branch offices or in the DMZ than you use on the LAN) Additional information: _____	☐	☐	☐
If policies, procedures or software differ in your network, use the "Additional information" area to explain differences where they exist. **Please provide an electronic copy of all firewall policies and procedures when you return this questionnaire to the auditors.**				
1.3	Has the current firewall administration and configuration policy been reviewed and approved by the Board of Directors or by management? *If the format of the firewall administration and configuration policy does not include an approval page with Board of Director or management signatures, please furnish a copy of the Board minutes in which the Information Security Program was approved.*	☐	☐	☐

Number	Question	Yes	No	N/A
	Additional information:			
1.4	Has the policy been implemented? Additional information:	☐	☐	☐
1.5	Is the firewall policy reviewed on a regular basis and updated as the environment changes? *Please provide evidence that the policy is regularly updated. This evidence may be in the form of a change or history log for the document or previous versions of the document..* Additional information:	☐	☐	☐
1.5.1	When was the last time the firewall policy was reviewed or updated?			
1.6	Do firewall policy and procedures include the following elements:			
1.6.1	Purpose	☐	☐	☐
1.6.2	Scope	☐	☐	☐
1.6.3	Periodic revision requirement	☐	☐	☐
1.6.4	Definitions (If required)	☐	☐	☐
1.6.5	Enforcement provisions	☐	☐	☐
1.6.6	Revision history	☐	☐	☐
1.6.7	The way in which firewall software or appliances should be configured	☐	☐	☐
1.6.8	A list of personnel authorized to change firewall configurations	☐	☐	☐
1.6.9	Backup of firewall configurations & off-site storage of configurations	☐	☐	☐
1.6.10	Updating firewall IOS	☐	☐	☐
1.6.11	Firewall logging and monitoring requirements	☐	☐	☐
1.6.12	A network administrator/help desk response process for attacks	☐	☐	☐
Additional Information for items in Section 1.6:				

2. Firewall Administration and Configuration

Number	Question	Yes	No	N/A
2.1	Is the Administration, configuration or operation of the firewall outsourced? Additional information:	☐	☐	☐
2.1.1	Who is the outsourced vendor?			

Number	Question	Yes	No	N/A
2.1	Is the site configured with an Isolation LAN (DMZ) Additional information:	☐	☐	☐
2.2	Describe the method used to limit access to the firewall's administrative interfaces:			
2.3	Are all management sessions to the firewall's administrative interfaces encrypted? Additional information:	☐	☐	☐
2.4	Briefly describe the ruleset for the firewall configuration(s): **Please provide firewall configuration files for all firewalls to the auditors when you return this questionnaire. If the firewall software or device does not support configuration export, provide screenshots of the configuration dialogs.**			
2.5	Is the firewall configured to deny all traffic by default and allow only traffic needed for the organization's requirements? Additional information:	☐	☐	☐
2.6	Are services and software that are not specifically required disabled on the firewall ? Additional information:	☐	☐	☐
2.7	Does the firewall perform only firewall functions and not additional functions such as anti virus scanning, content filtering , VPN, DHCP, etc? Additional information:	☐	☐	☐
2.8	If possible, is the firewall service run under a unique user ID instead of administrator or root? Additional information:	☐	☐	☐
2.9	Has the default administrator or root password on the firewall been changed? Additional information:	☐	☐	☐
2.10	Is the firewall configured to use stateful packet inspection instead of packet filtering? Additional information:	☐	☐	☐
2.11	Does the firewall ruleset include filtering packets for correct addresses based on the SANS Top 20 Vulnerabilities List? Additional information:	☐	☐	☐
2.5	Is the firewall configuration backed up and stored securely in an off-site location?	☐	☐	☐
2.6	Describe the process for upgrading the firewall's IOS (who authorizes the upgrade, etc.):			
2.7	Who is authorized to change the firewall configuration?			
2.8	Is the firewall configured to alert administrative personnel when threats are detected?	☐	☐	☐
2.9	Are firewall logs captured?	☐	☐	☐

Number	Question	Yes	No	N/A
2.10	Are firewall logs reviewed?	☐	☐	☐
2.10.1	How often are logs reviewed?			
2.10.2	Who reviews the firewall logs?			

3. Consolidated Request List

Number	Requested Item	Provided	Not Provided	Reason not provided
3.1	Electronic copy of any/all firewall policies, procedures or programs in effect	☐	☐	
3.2	Electronic copy of the firewall configuration file(s). (If the software does not support exporting configurations, please provide screenshots of the configuration dialogs)	☐	☐	

4. Additional Information for the Auditor on Firewall Administration and Configuration